



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Vulnerabilities of the cyber space

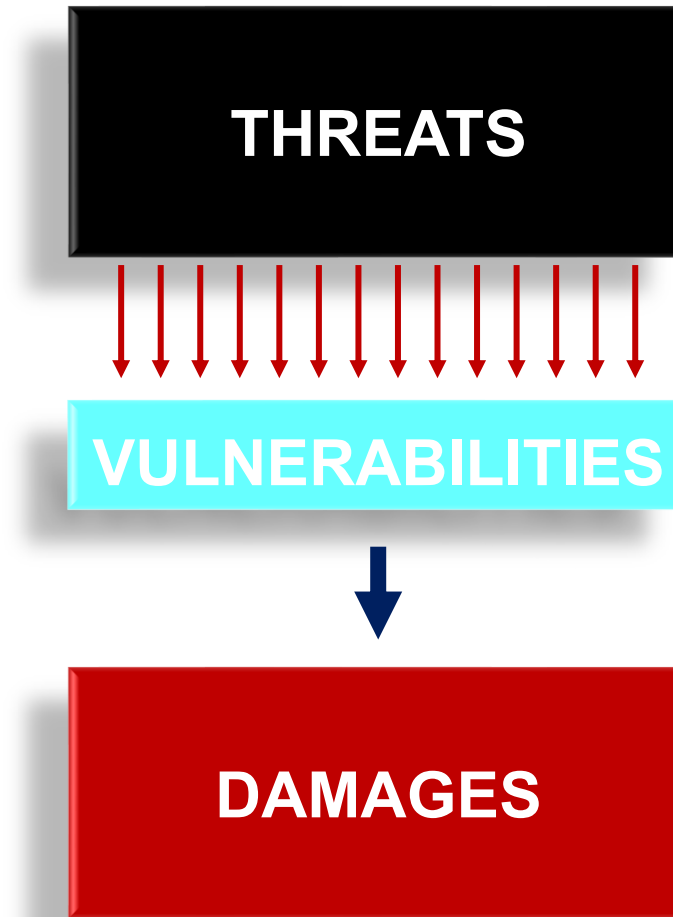
Michele Colajanni

Dipartimento di Informatica – Scienza e Ingegneria
michele.colajanni@unibo.it

Fundamental principles

- 1) **Threat and risk analysis models:** “who the attacker is, what they want, and what the attack surfaces are” remains the same, regardless of the technology.
- 2) **Fundamental vulnerability classes:** *user-related vulnerabilities*, *software-related vulnerabilities* (buffer overflows, code injection, race conditions, memory management issues) remain the same. The languages in which they manifest may change, but the underlying logic does not. The same for *system* and *management vulnerabilities*.
- 3) **Cryptography, its mathematical primitives (RSA, elliptic curves, hashes), and associated protocols:** implementations change, but the underlying theory does not. [With the exception of *quantum-safe cryptography*.]
- 4) **Secure design principles:** **least privilege**, **strong authentication**, **defense-in-depth**, and **fail-safe defaults** (explicit permissions rather than default ones) remain perfectly valid in any architecture.

Cyber risks



Two main classes of *vulnerabilities* in cyber space

HUMAN

TECHNOLOGIES



And *vulnerabilities* can be subject to different *threats*

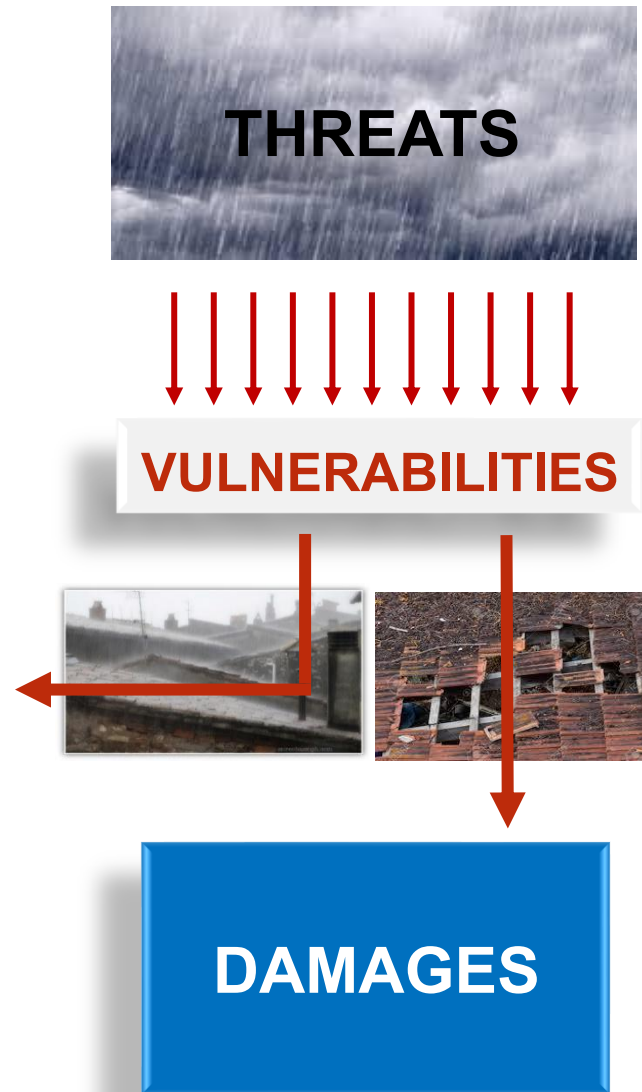


HUMAN

TECHNOLOGIES



For example, rain is a threat. *What about your roof?*



Components of the cyberspace. Anything in common?

Interconnection technologies



People



Databases



Applications



Operating systems

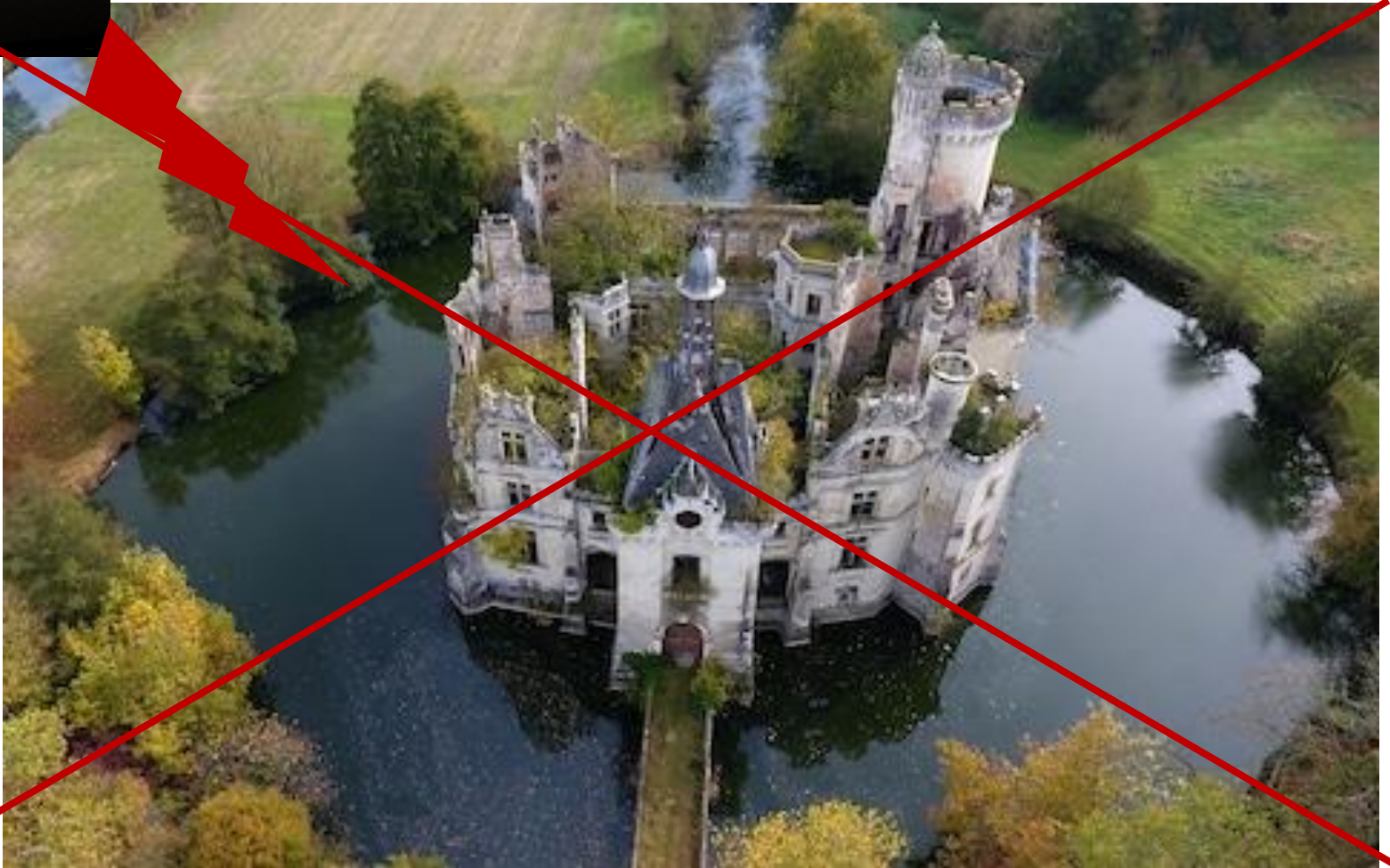


Hardware and
Infrastructures

ALL VULNERABLE



Cybersecurity is not about how to defend a castle because no organization is a castle

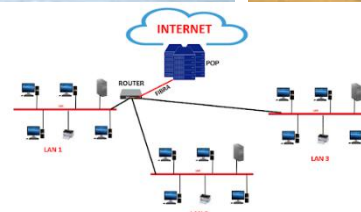
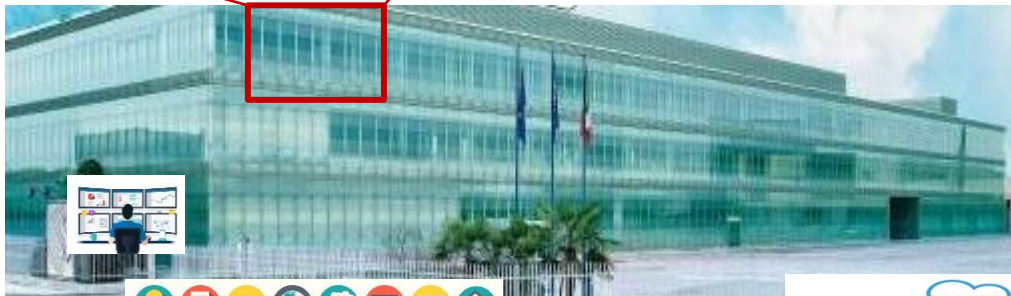


Vulnerabilities of an organization



Email (>1)
Linkedin, Facebook
Messenger, WhatsApp
Internet Service Provider
Online banking, Amazon
Meet, Zoom, Teams
Dropbox, Azure 365, Google Docs
AirNnB, Expedia, Hotels, Lastminute
Trains, Airlines

**PC – Laptop
Smartphone**



Attack surface

The attack surface of an enterprise is represented by all the points where an adversary can attempt to gain entry to the information systems → Basically, any technique that a human threat can use to get unauthorized access to the company's resources through any asset

- For a medium to large sized enterprise, **the attack surface can be gigantic** → Thousands and thousands of assets potentially targeted by hundreds of attack vectors can mean that an attack surface can be made up of hundreds of thousands of targets

This huge surface should be protected, vulnerabilities fixed, and all resources always monitored for detecting *anomalies* (that are signals of technical issues or attacks)



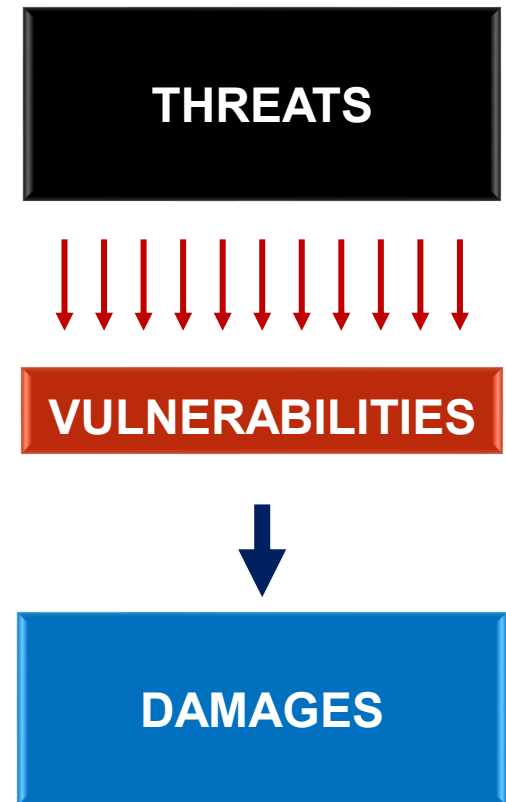
Consequences (1)

The good expectation

If the main cybersecurity problems are represented by the vulnerabilities, then you can guarantee security by fixing all of them

The bad reality

1. **Finding** most vulnerabilities is *rather* easy (e.g., VA, PT, even through AI support)
2. **Fixing** all vulnerabilities –assuming that you can know all of them– is extremely expensive (in terms of people, time and resources) even because they change continuously



Consequences (2)

You cannot expect that you will be able to *know* all vulnerabilities and even less that you can *fix* each of them

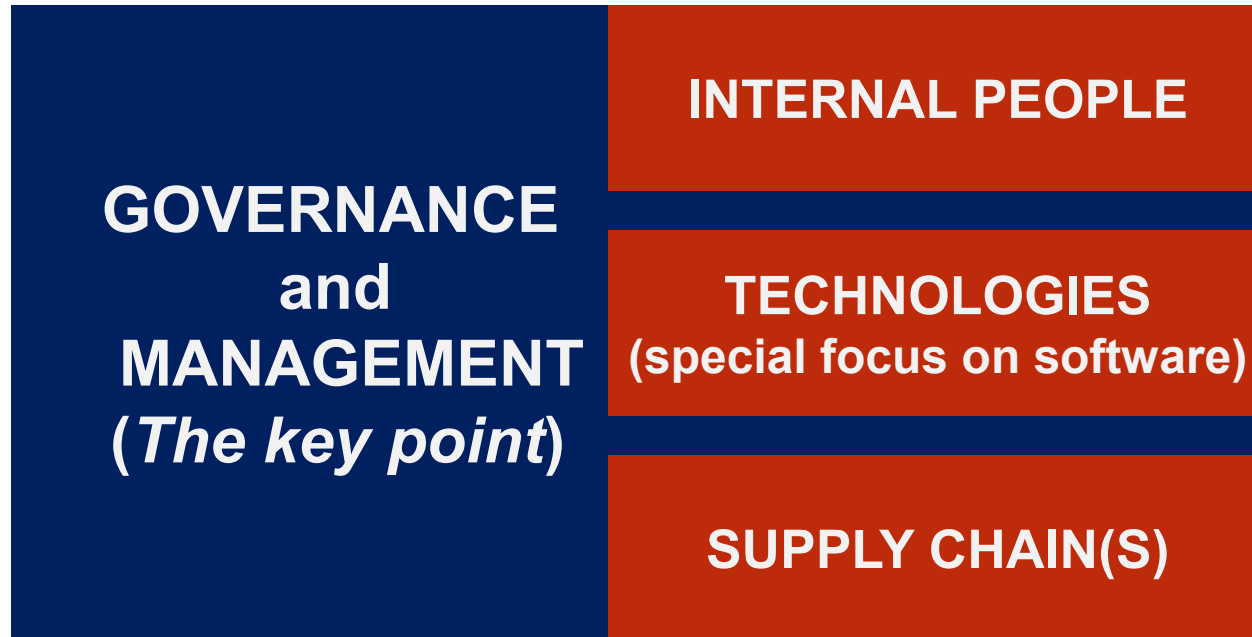
WHAT
TO DO



- 1) PRIORITIES OF PREVENTIVE METHODS
- 2) REMEDIATION METHODS AFTER INCIDENTS



Main classes of vulnerabilities affecting organizations



Exercise: Find examples

Identify some examples of vulnerabilities for each of the following four categories

*(**internal** vulnerabilities, not **external** threats)*

- 1. Internal people**
- 2. Supply chain(s)**
- 3. Technologies**
- 4. Management**



Internal people: *who are they?*

- **Board**
- **Managers**
- **Employees**
- **“Special” employees**
 - **Administrators:** systems, network, database, Web, ...
 - **Software teams:** architects, developers, testers, ...
 - **Security responsible:** physical, cyber
- **Temporary contractors, interns**



Vulnerabilities: *Internal people*

Incompetent or **negligent** actions of

1. Managers
2. System administrators
3. Employees
4. Temporary interns (e.g., stage)

Malicious actions of

1. Temporary interns not confirmed
2. Fired employees
3. Disgruntled employees
4. Greedy employees and system administrators (*corrupted, blackmailed, threatened*)



Negligent human vulnerabilities

Actions not deliberated:

- inexperience, incompetence
- lack of knowledge of the rules, lack of rules



Underestimated actions:

- no or little respect of company norms and norms in general
- low probability of being discovered and poor perception of crime



- Click a wrong link or a wrong email attachment
- Choose a trivial password, do not change the default password, store a password improperly, reuse a password in multiple sites
- Insert an infected pen-key
- Install a fraudulent app
- Use unknown insecure Wi-Fi networks
- Publish **inappropriate information** on some social network(s)
- ...



Deliberated human vulnerabilities

Deliberated actions:

- disappointment and revenge (80-90%)
- ideology
- (im)moral issues
- challenge (antisocial tendencies) and curiosity
- corruption
- blackmail



Threats or Vulnerabilities ?



Malicious employees: *Suspicious (anomalous) actions*

Digital (technical) Suspects

- Downloading or accessing of substantial amounts of data
- Unauthorized access to unrelated critical data
- Multiple requests to access data, not related to job function
- Usage of unauthorized storage devices such as USB drives or disks
- Network crawling and frequent requests for sensitive data
- Data hoarding and file copying from sensitive folders

Behavioral Suspects

- Attempts to bypass security (piggybacking/tailgating)
- Frequent visits to office during off-hours
- Displaying disgruntled behavior towards co-workers
- Frequent (even small) violation of corporate policies
- Discussing about resigning from the company or about new opportunities

Pay attention to the
legal constraints in
your country

In Italy: *Job's Act*,
GDPR



Careless or incompetent employees: *Human vulnerabilities → Technical vulnerabilities*

Motivations

- Psychological
 - Credulity
 - Curiosity
 - Exhibitionism
 - Greed
 - Ideology
 - Lust
 - Misplaced trust
- Mood
 - Anger
 - Boredom
 - Dissatisfaction
 - Fatigue
- Incompetence

Consequent vulnerabilities

Choice of weak passwords
Data exposure
Loss of devices
Manipulations by threat actors
Misconfiguration
Missed backups
Non-compliance to rules
Non-use of encryption
Password sharing
Preference for simple (although insecure) work processes
Thoughtless click on links and attach.
Thoughtless use of social networks
Use of unpatched software
...

ATTACK

*Remember
when you
promote
defenses*



Compromised employees

- “Compromised users” are not *healthy paranoid (like us)*; hence they are often unaware that they can fall into some cyber attackers’ trap
- For this reason, they are the **most common** and **critical** types of *vulnerable users* that can easily become unknowingly responsible for a cyberattack to your organization

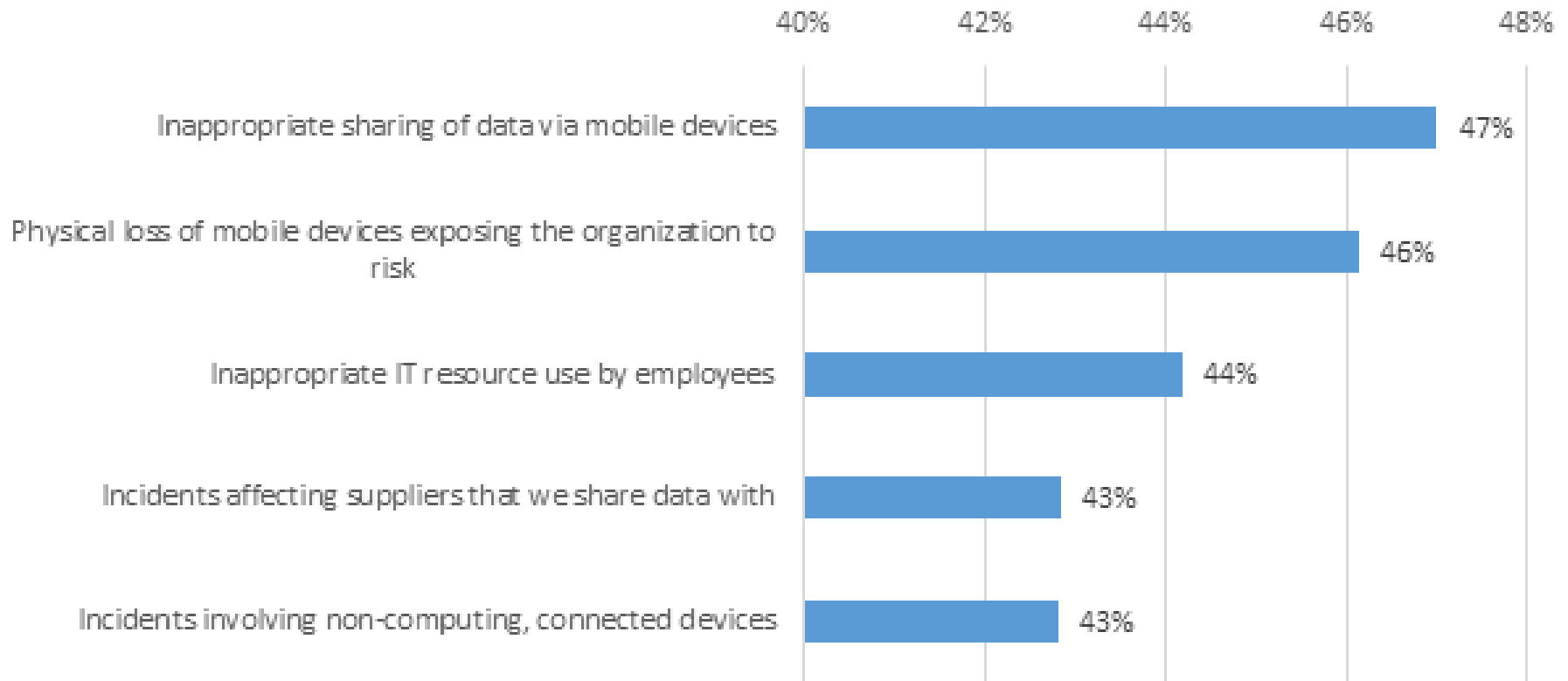
They can be employees of:

- Your organization
- Business contractors
- Vendors
- Suppliers
- Partners
- ...



Top five (fears of) vulnerabilities

Where do businesses feel vulnerable? Top five fears



Always ask to yourself: *Are these statistics valid for my organization?*



“Special” category: *Administrators / Super Users*

Interventions not done or badly done:

1. Authentication mechanisms
2. Separation and Authorization at the level of:
 - Networks
 - Services
 - Information (*need to know*)
3. Mobile device management
4. Detection mechanisms
5. Logging systems and monitoring
6. Software installation and configuration
7. Software integration
8. Patch management process
9. ...

If your organization has no policies (huge vulnerability!), it is the *unofficial* duty of SysAdmins to promote them to the top managers

Beware of excess of pride and self-consideration!

Just as all metals can melt, all people including SysAdmins can be vulnerable to S&M



Other “critical” categories of suppliers’ employees

Software production

Cybersecurity

are often outsourced or are partially outsourced



Vulnerabilities: *Supply chain(s)*

Incompetent, negligent or malicious actions of

1. **Consultants**
2. Employees of **supplier** companies
3. Employees of **controlled**
4. Employees of **partnership** companies (*open innovation* is the new mantra)
5. Providers of
 - Hardware
 - Software
 - Services
 - Cybersecurity solutions



The worst challenges with suppliers

1. Lack of complete **visibility**

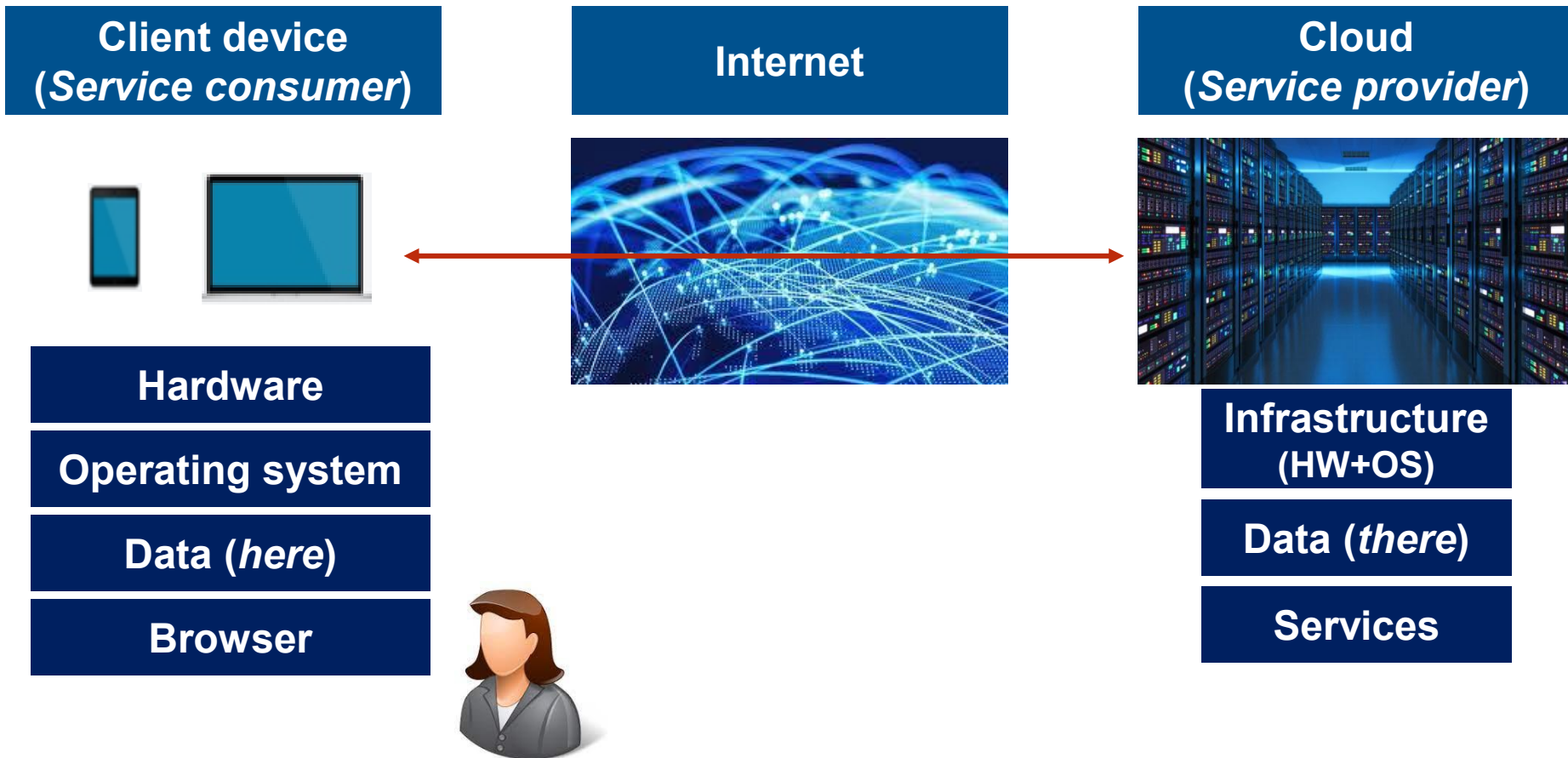


2. Lack of device **inspectability**

- In the real world, “possession” implies possibility of control
- In IT, *possession* and *control* are decoupled. Is it possible to establish with certainty who is in control of a given device?



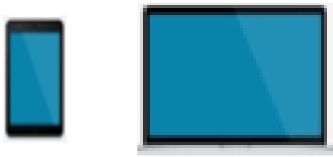
Personal example: *What do you really own?* *And what can you really control?*



The typical scenario of digital services

What do I really own?

Client device
(Service consumer)



Hardware

Data (here)



“Either you TRUST or you TRUST”

And even if I possess a physical device, this does not mean that I can inspect its internals

Everything is regulated by the *Terms of Service (ToS)* or *Terms of Use (ToU)*

Terms of Service

These Terms of Service (“Terms”) govern Your access and use of the Veritone.com website (the “Site”) and any software, programs, materials, and services made available through this Site (collectively, the “Services”). When You access and make use of the Site and the Services, in their present form or as they may be modified from time to time, You are agreeing to these Terms, which create a legally binding agreement between You and Veritone, Inc. (“Veritone” or the “Company”)



Vulnerabilities: *Technologies*

1. Obsolete or missing physical protections (e.g., unprotected storage, over-heating, unprotected communication lines)
2. Badly designed and implemented network architecture → often lack of separation and segregation (networks, people); today also on-premise, hybrid and cloud architectures
3. Obsolete or missing logical protections (e.g., firewalls, antivirus)
4. Insecure configurations of networks, systems, software and firewall
5. Poor authentication mechanisms
6. Lack of (continuous, controlled and separated) secure backups
7. Lack of continuously monitoring and installation of software patches at the endpoint and server level
8. ...

**The most serious
technical vulnerability**



The most serious technological vulnerability: *Software*

Software (providers) → *Vulnerable software*

- insecure coding
- design flaw
- insufficient testing
- lack of audit trail
- lack of software patches after vulnerability disclosure
- ...

Software (users)

- Use of illegal software (not licensed)
- Incompetent installation
- Lack of a patch management processes



(Lack of) GOVERNANCE and MANAGEMENT

1. Missing, inadequate, not implemented or unverified security policies
2. Inadequate Authentication mechanisms
3. Lack of Authorization mechanisms (*need to know*)
4. Not regularly verified Logging systems
5. Inadequate mobile device management
6. Incident Management inadequate or missing
7. Lack of control over suppliers
8. Lack of delegation of responsibility
9. Failure to supervise
10. Lack of detection mechanisms
11. Lack of a patch management process

Top
Vulnerability



Top-down overall approach to cybersecurity (*vulnerabilities exist because some activities are missing*)

